

Rapport SAE 4.01

Carte interactive : Zelda: Link's Awakening

Sommaire

Sommaire	1
Introduction	1
Sujet.....	1
Présentation du projet.....	1
Présentation du groupe et rôle de base	2
Suivi de projet	3
Conception et déroulement du projet	5
Détail et justification des outils utilisés en interne	5
Mise en place du projet.....	5
Déroulement du projet	6
Sécurité du projet	13
Détail des protections	13
Conclusion	18
État du projet.....	18
Conclusions personnelles (qu'est-ce que nous avons appris, les choses que le projet a confirmées ou remis en cause)	18
Prolongements imaginés pour le projet	18
Les choix technologiques et architecturaux étaient-ils bons ?	19
Quels seraient les axes d'amélioration pour vos futurs projets	19

Introduction

Sujet

En équipe de 2 à 4, optimiser une application existante en suivant une approche itérative ou incrémentale, en mettant l'accent sur la qualité, l'accessibilité, la sécurité et l'impact environnemental.

Pour cela, vous pouvez reformer des groupes différents de ceux du semestre précédent ou les conserverez, repartir sur votre projet ou demander le projet d'un autre groupe (2A ou 3A) sous réserve de validation de l'équipe pédagogique.

Présentation du projet

Lien vers le dépôt GitHub du projet : <https://github.com/Unicron03/map-LA-upg>

Lien vers le site : <http://zeldala.duckdns.org/>

Vous pouvez utiliser un compte exemple : account.example@gmail.com Pi02Gt67&*

Le lien d'accès direct au site est susceptible de changer. Vous trouverez donc le lien mis à jour sur le dépôt GitHub (hébergé sur le NAS d'Enzo VANDEPOELE avec donc une base de données uniques à tous).

La carte contient des *markers* (des points d'intérêt du jeu). Vous pouvez alors **sélectionner un *marker* pour obtenir des informations sur ce dernier** (lien vers la solution, image provenant du jeu, description, titre, fonctions de favoris, etc.).

La carte contient plus de 140 marqueurs communs à tous les utilisateurs. Toutefois, vous pouvez, *en vous créant un compte et vous connectant*, **créer des marqueurs personnalisés** dont vous seuls avez le contrôle (titre, description, etc.). La connexion vous donne également accès à quelques fonctionnalités supplémentaires tel que d'avantages d'options de filtres ou encore la possibilité de marquer en "Favoris" ou en "Complété" les marqueurs communs.

Tips : Si vous ajoutez un marqueur en favoris ou complété, vous obtiendrez un joli badge dans le coin du marqueur !

Étant donné le grand nombre de marqueurs sur une carte d'une telle taille, des filtres sont à votre disposition afin de sélectionner rapidement les marqueurs que vous souhaitez voir. Dans le but de faciliter les déplacements de personnes n'utilisant pas de souris, des contrôles sont à votre disposition (zoom, dézoom et reset).

Une documentation expliquant le fonctionnement complet de l'application est d'ailleurs.

Présentation du groupe et rôle de base

VANDEPOELE Enzo – Alternant à Évoléa (Secteur immobilier) en tant que Technicien SI posté sur la cartographie des données et le développement d'une IA de recherche interne.

Je suis à doter d'une très grande force de travail et de sérieux. Très polyvalent, exigeant et pointilleux sur les détails pour atteindre le meilleur produit possible.

Rôle dans le groupe : Conduire le projet (chef de projet), améliorer l'ergonomie du site et de ses visuels, réduire au maximum les rafraichissement de l'application, et résoudre tous les bugs connus (hors sécurité). Enfin, je suis chargé de mettre en ligne l'application grâce à mon NAS.

MICALLEF John - Alternant à la DGFIP en tant que OPS (création et configuration de VM), je serais aussi chargé de réaliser une IHM.

Je suis quelqu'un de calme et sérieux. Je suis rigoureux, c'est-à-dire que j'aime bien suivre à la lettre le cahier des charges.

Rôle dans le groupe : Sécuriser le site (CSRF, attaque XSS, injection de code, etc.), dockeriser, et faire l'export automatique de la base de données.

AHOUAN DOGBO Amen – Alternant à la SNCF en tant que Développeur Valorisation de la performance (avec des outils type Power BI). Je suis chargé de développer des outils d'aide à la décision.

Je suis quelqu'un de respectueux ayant le sens de la responsabilité. Je suis aussi sérieux que travailleur et exigeant envers moi-même.

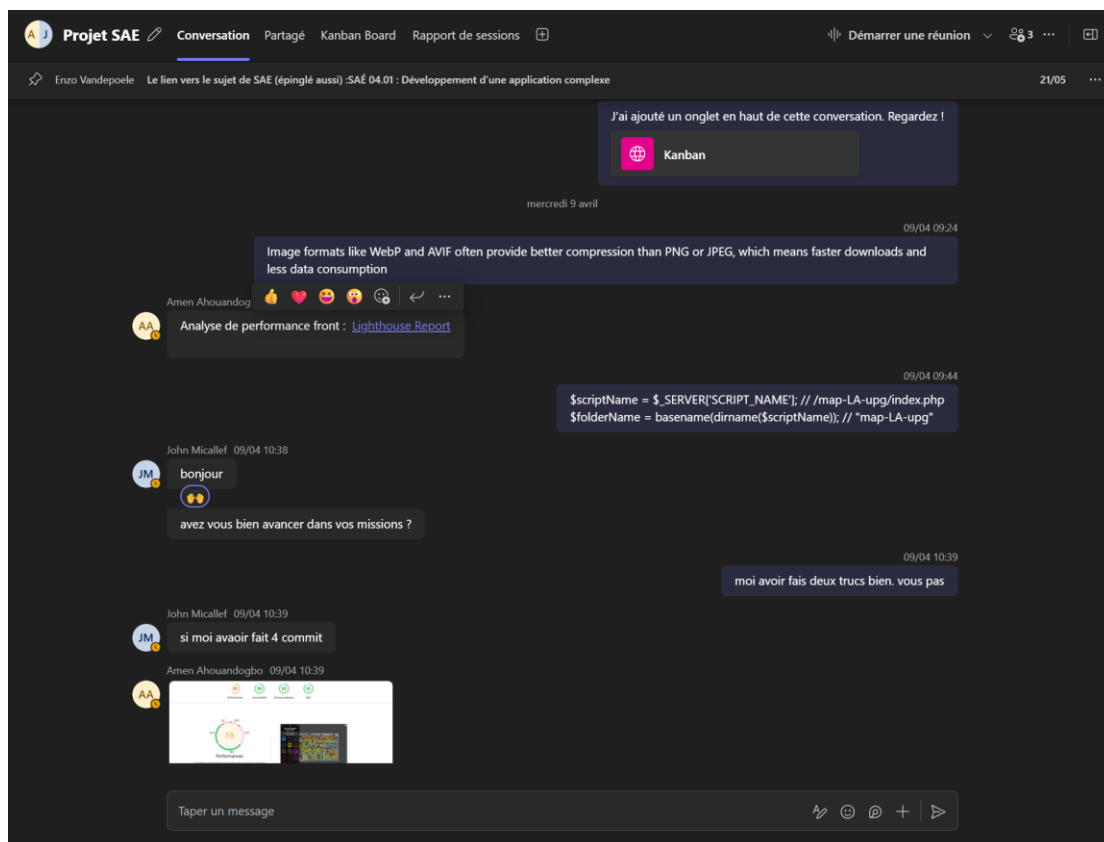
/

Suivi de projet

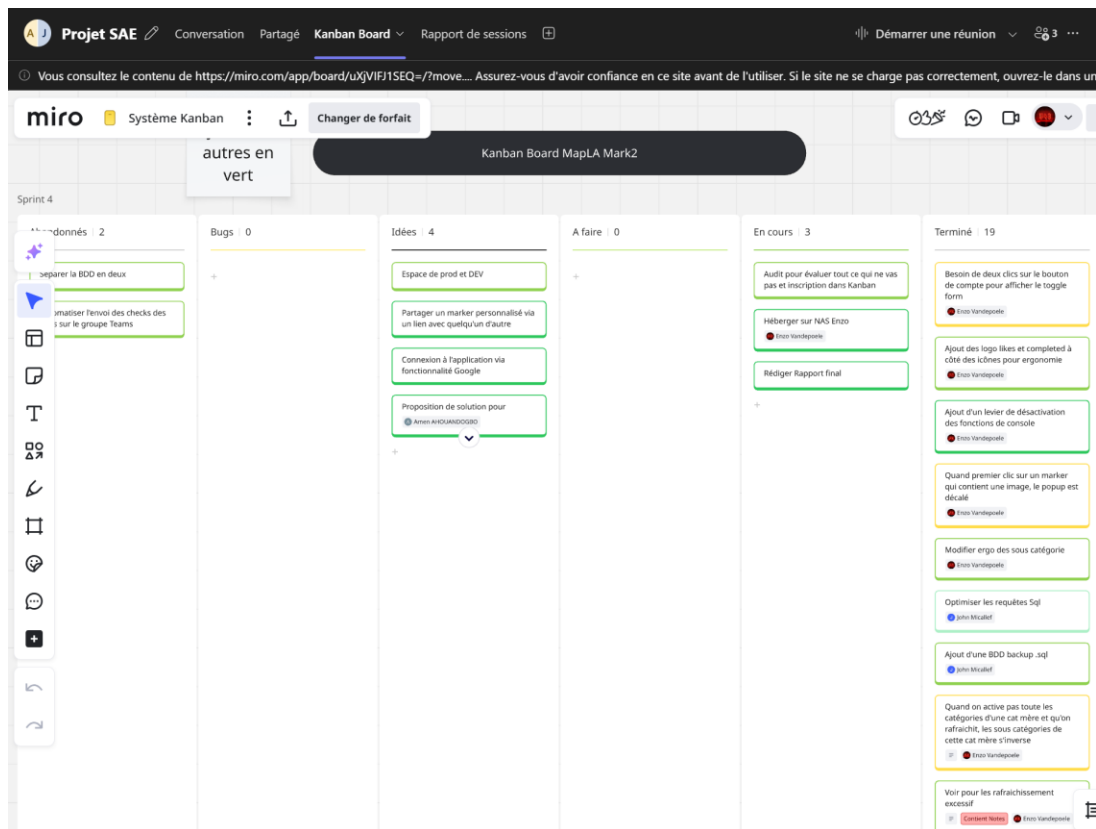
Pour pouvoir optimiser et fluidifier notre travail, nous avons mis en place toute une démarche de suivi de projet.

Déjà, nous avons mis en place le GitHub et nous sommes bien mis d'accord sur le fait de faire des commits explicite (quitte à ce qu'ils soient longs).

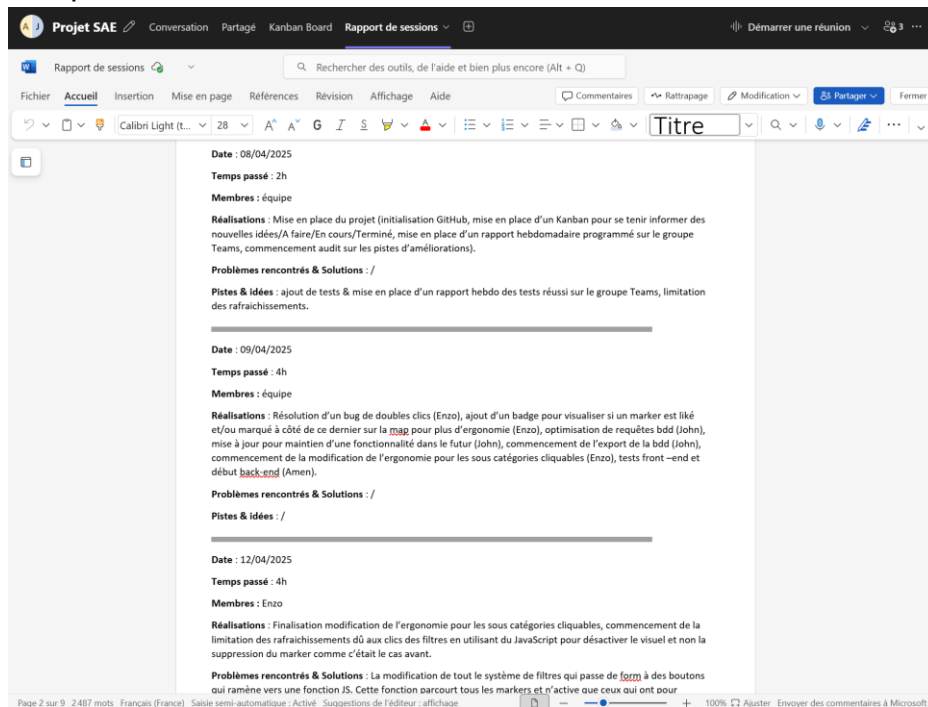
Nous voulions regrouper au maximum les outils qu'on a pu utiliser afin d'éviter une pénibilité et abandon du suivi. Pour cela, nous avons fait en sorte de regrouper tous ces outils sur Teams dans un même groupe au travers de section :



Dans un premier temps, nous avons mis en place un tableau Kanban nous permettant de trier les tâches à faire, celle en cours, et celle terminée :

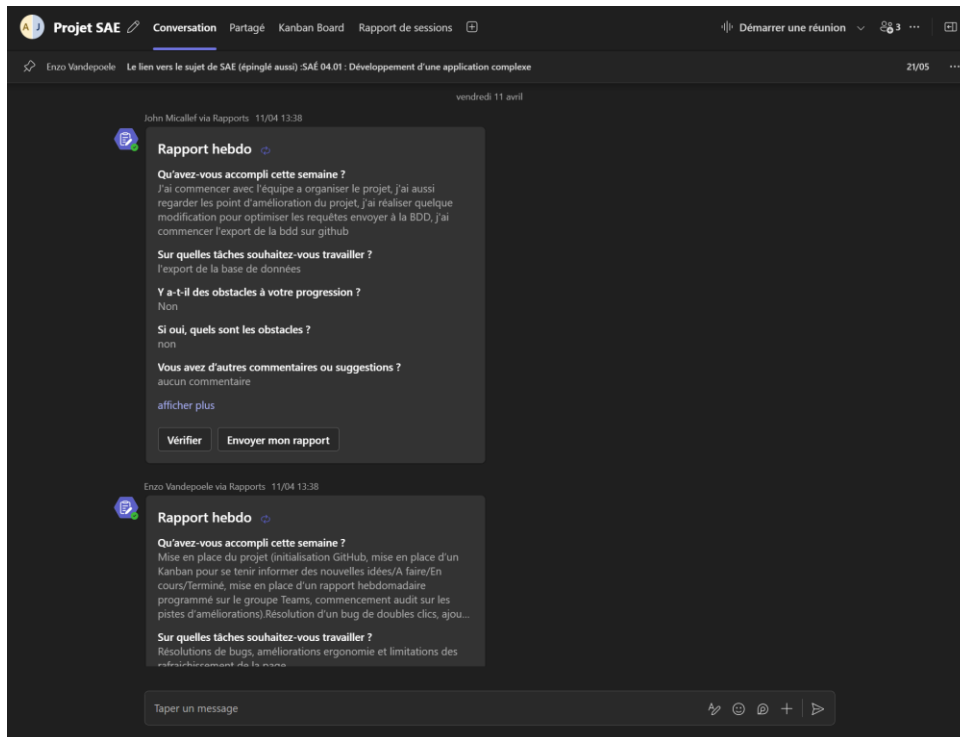


Nous avons également ajouté un rapport de session qui doit être complété après chaque session de travail.



Enfin, nous avons automatisé l'envoi hebdomadaire d'un formulaire sur le groupe Teams chaque vendredi que chacun doit remplir. Ce formulaire permet de faire état de ce qu'à fait chacun, des difficultés rencontrées et des nouvelles idées.

S'il s'avère que quelqu'un inscrive des difficultés dans son formulaire, alors le groupe devait se retrouver en réunion pendant le week-end.



Conception et déroulement du projet

Détail et justification des outils utilisés en interne

Pour réaliser ce projet, nous avons dû faire le choix de privilégier des outils :

- Pour la communication : Teams ;
- Pour les outils de suivi : Jira (Kanban), Formulaire hebdomadaire Teams, Rapport de sessions Teams ;
- Pour le stockage, hébergement et gestion de versions : GitHub, Git ;
- Serveurs utilisés : GitHub Pages (pour la récupération des images de map), XAMPP (pour le développement local), Docker (pour la virtualisation) ;
- Pour le développement : VS Code ;
- Pour la rédaction des rapports : Suite Office ;
- Pour la mise en ligne du site : Le NAS d'Enzo VANDEPOELE ;
- Langages utilisés : PHP, SQL, HTML, CSS, JS, Markdown.

Mise en place du projet

Avant de commencer quoi que ce soit, nous avons mis en place toute une étape de suivi de projet [que vous trouverez précédemment](#).

Après cela, nous avons réalisé un audit afin de :

- Comprendre l'architecture et le fonctionnement de l'application ;

Cela à était plutôt simple étant donné que nous avons repris notre ancien projet.

- Identifier les faiblesses techniques et ergonomiques ;

Nous avons relevé les avantages/inconvénients de notre projet par rapport à des solutions similaires existantes <https://zeldamaps.com/?game=LA>.

- Détecter les failles de sécurité potentielles ;

Grâce à l'aide de nos professeurs et d'analyse Light House.

- Évaluer l'impact environnemental ;

Nous avons estimé l'impact environnemental avec Light House et pris en compte cet aspect dans le développement.

- Définir des outils et méthodes de suivi des optimisations ;

L'analyse Light House nous donne directement des scores de performances et d'optimisation.

- Mettre en place une stratégie de test adaptée.

Nous avons réalisé une batterie de tests PlayWright pour couvrir l'ensemble des fonctionnalités de l'application, et des stress test avec Artillery pour voir comment se comporte l'application avec beaucoup d'utilisateurs.

Déroulement du projet

Pour avoir une idée de ce que chacun à fait par rapport aux missions de base de chacun, nous vous invitons à vous diriger vers le carnet de bord qui contient TOUTES nos sessions de travail.

Néanmoins, voici un résumé de ce que chacun à réaliser par rapport aux tâches de chacun :

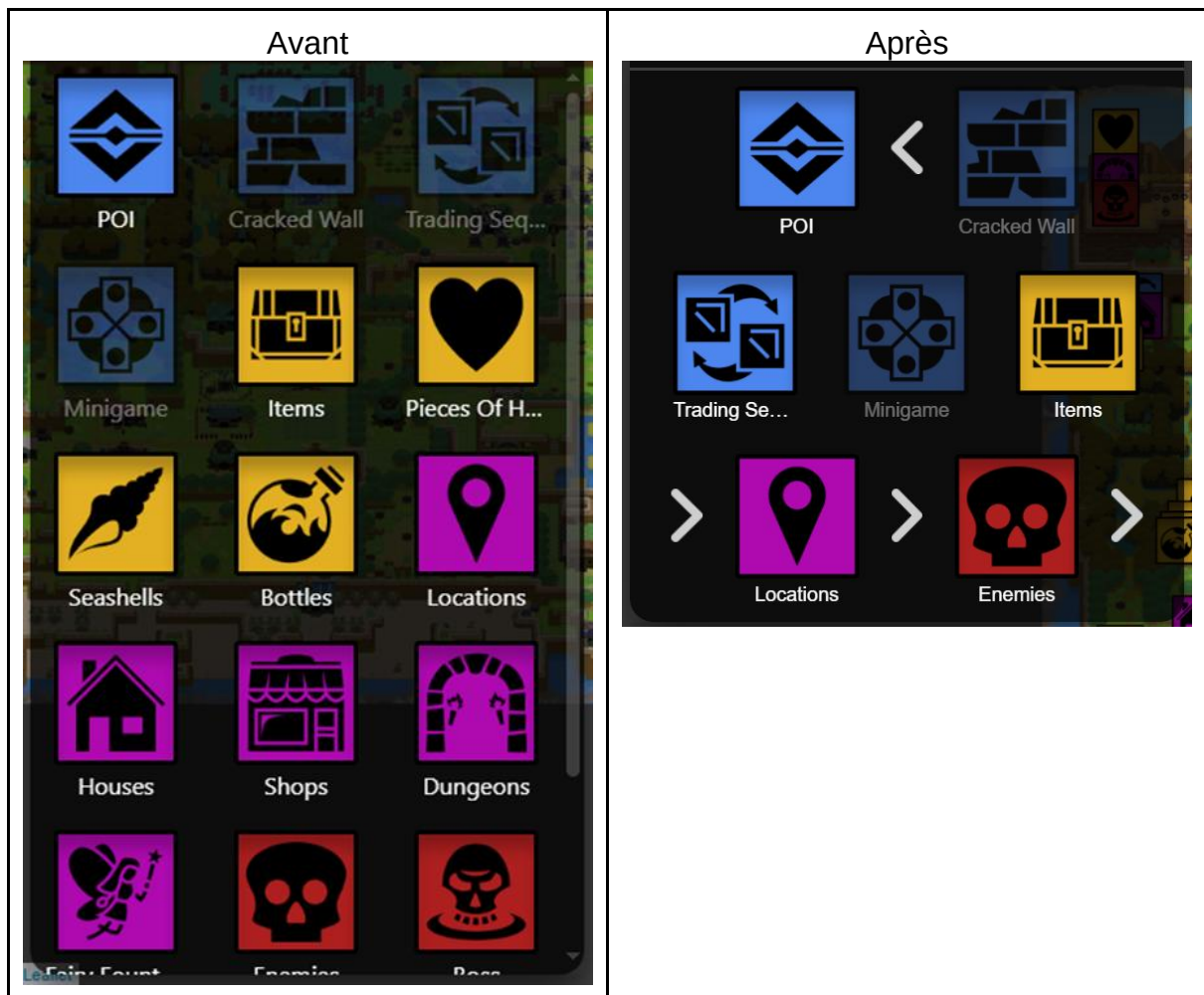
- Enzo :
 - ~~Conduire le projet~~

J'ai mis en place des outils de gestion type Kanban (Jira), rapport de session, GitHub avec commit explicites, rapport hebdomadaire automatique de travail sur Teams et pris des décisions par rapport aux difficultés et changement possibles (en organisant des réunions notamment et agir en conséquence).

J'ai selon moi effectuer ma tâche avec succès et ai su gérer l'équipe vers un projet qui coche toutes les cases de ce que nous nous étions fixés, et ce, malgré les problèmes de chacun.

- ~~Améliorer l'ergonomie du site et de ses visuels~~

J'ai amélioré les visuels qui faisaient légèrement tâches telles que les formulaires de modification et d'ajout de marqueur. J'ai également amélioré l'ergonomie du panneau de filtres en ajoutant des catégories mères/filles rétractables.

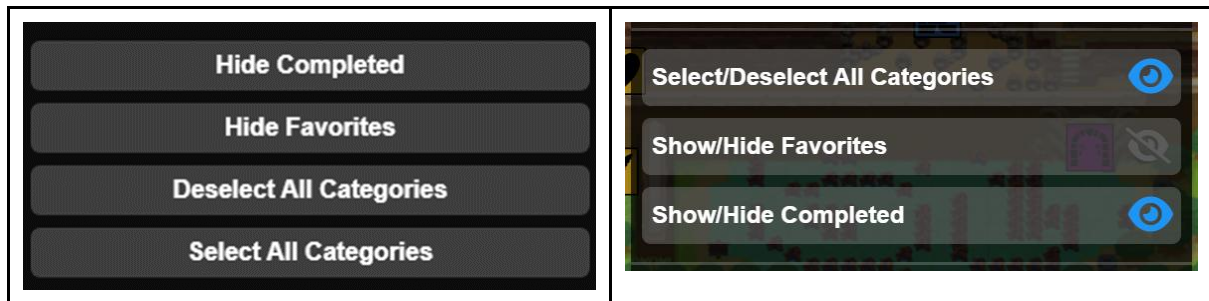


J'ai aussi ajouté des badges à côté d'un marqueur sur la carte indiquant si ce dernier à été marqué comme liké ou complété.



Enfin, j'ai ajouté un levier d'activation pour les filtres secondaires, ce qui permet au passage d'en regrouper (exemple : Activer/Désactiver tous les marqueurs).

Avant	Après
-------	-------



- ~~Réduire au maximum les rafraichissement de l'application~~

J'ai réduit au maximum les rafraîchissements de l'application en passant d'un système côté serveur en PHP à un système client en JavaScript. Cela permet d'alléger la charge du serveur et de profiter d'une bien meilleure expérience utilisateur. Cela est permis grâce aux requêtes AJAX et à la simulation d'interaction serveur.

Prenons un exemple : la mise en favoris d'un marqueur.

L'utilisateur clic sur le bouton de mise en favoris dans un popup de marqueur. Cette action va alors appeler un script que voici :

```
/**
 * Fonction formatant les données d'un marker à marquer comme favoris
 pour validation et envoi
 */
function markAsFavorite(event, id) {
    event.preventDefault();

    fetch('scripts/management/bdd/markAsFavorite.php', {
        method: 'POST',
        headers: { 'Content-Type': 'application/x-www-form-urlencoded' },
        body: new URLSearchParams({ id })
    })
    .then(() => {
        const marker = getMarkerElementByUnicId(id.toString());
        if (!marker) return;

        const markerImgDiv = marker.querySelector('div'); // le div
        // contenant l'image
        if (!markerImgDiv) return;

        const badge = markerImgDiv.querySelector("img[src='./img/like.png']");
        if (badge) {
            badge.remove(); // Supprime le badge s'il existe
        } else {
            const img = document.createElement("img");
            img.src = './img/like.png';
        }
    })
}
```



```

        img.style = 'position: absolute; bottom: -6px; left: -6px; width: 16px; height: 16px;';
        markerImgDiv.appendChild(img); // Ajoute le badge
    }

    map.closePopup(); // Ferme le popup
})
.catch(error => console.error('Erreur:', error));
}

```

Ce script appelle le script suivant avec l'opération *'fetch'* qui met en favoris le marqueur dans la base de données :

```

<?php
session_start();

try {
    // Connexion à la base de données
    $pdo = new PDO("mysql:host=db;dbname=map-la",
$_SESSION["pdoUserName"], $_SESSION["pdoUserPassword"], [
        PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION,
        PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC
    ]);

    // Vérification de l'ID passé en paramètre POST
    if (!isset($_POST['id']) || empty($_POST['id'])) {
        die('ID manquant'); // Si l'ID est absent, afficher un message d'erreur simple.
    }

    $id = $_POST['id'];

    // Préparer et exécuter la requête
    $stmt = $pdo->prepare("SELECT typeMarker FROM marker WHERE id = ?");
    $stmt->execute([$id]);
    $markerTypeId = $stmt->fetch(PDO::FETCH_ASSOC); // Récupère directement une ligne

    if ($markerTypeId['typeMarker'] == 16) {
        $stmt = $pdo->prepare("UPDATE marker SET favorite = NOT favorite WHERE id = ?");
        $stmt->execute([$id]);
    } else {
        $stmt = $pdo->prepare("UPDATE userdata SET favorite = NOT favorite WHERE idMarker = ? AND userId = ?");
        $stmt->execute([$id, $_SESSION['user_id']]);
    }
}

```

```

    }

    // Terminer simplement l'exécution après la mise à jour
    exit();
} catch (PDOException $e) {
    die('Erreur SQL : ' . $e->getMessage()); // En cas d'erreur, afficher
un message simple.
}

```

Une fois l'opération '*fetch*' terminé, *markAsFavorite* va créer les badges et modifié le popup en JavaScript. Si l'on rafraichit, alors les modifications seront automatiquement chargées grâce à l'opération faite précédemment avec '*fetch*'.

À ce jour, TOUS les rafraichissements ont été supprimés sauf 2 pour la mise à jour d'un marqueur (très compliqué à mettre en place, car les popups ne sont pas récupérables. Seul un popup ouvert est atteignable).

- ~~Résoudre tous les bugs connus (hors sécurité)~~

J'ai résolu un nombre de bugs très conséquent, aussi bien ceux qui provenaient de l'ancienne version, que ceux créés par les nouveaux ajouts.

Voici une liste très exhaustive des bugs que j'ai résolu:

- Besoin de deux clics sur le bouton de compte pour afficher le toggle form ;
- Quand premier clic sur un marker qui contient une image, le popup est décalé ;
- Quand on active pas toutes les catégories d'une cat mère et qu'on rafraichit, les sous-catégories de cette cat mère s'inversent ;
- Quand on clic sur un marker le popup s'ouvre. Mais si ensuite on clic sur le filtre additionnel "Deselect All", alors le popup ne se ferme pas ;
- Résolution d'un bug où les popups Leaflet ne se fermaient pas si on exécutait des filtres ensuite.

Il était absolument nécessaire de résoudre ces bugs qui entachent l'expérience utilisateur.

- ~~Mettre en ligne l'application~~

J'ai complété la Dockerisation réalisé par MICALLEF John en remplaçant l'ancien projet par le nouveau, et j'ai donc dû adapter un grand nombre de liens, notamment pour convenir aux conteneurs docker.

Après cela, j'ai pu ajouter dockerisé le projet sur mon NAS (Windows 11) pour ensuite rediriger les bons ports de mon réseau vers le projet.

4

✕

Nom de la règle

Protocole

TCP
 ▼

Équipement

HP-NAS_Ev
 ▼

Port externe

RESTREINDRE CETTE REGLE AUX FLUX ENTRANT AYANT L'IP SOURCE (OPTIONNEL)

Port interne

La règle "Docker" redirige le protocole TCP pour les flux Internet ayant le port 80 de la bbox vers le port 8080 du périphérique

SUPPRIMER

DUPLIQUER

ANNULER

APPLIQUER

Enfin, j'ai sécurisé mon IP box en utilisant DuckDNS pour obtenir un lien correct :

<http://zeldala.duckdns.org/>

Cela permet donc une bonne rapidité, et surtout un logiciel et une base de données unifié qui nous permet de réagir bien plus facilement et rapidement en cas de problème. Aussi, c'est un avantage conséquent pour la maintenabilité du projet.

J'ai par ailleurs travaillé sur d'autres tâches ou les ai complétés :

- J'ai ajouté un levier de désactivation des fonctions de consoles (ce qui permet de modifier que la paramètre d'appel à la fonction quand on souhaite passer du développement à la production et vice-versa).
- J'ai également réalisé tous les tests PlayWright et mis en place les tests de stress avec Artillery. C'était normalement une tâche de AHOUANDOGBO Amen, mais ce dernier par manque de temps ne s'en est pas occupé.

- John :

- Sécuriser le projet

Je me suis chargé de la sécurisation des différentes pages du projet. Vous pouvez consulter l'ensemble des actions réalisé dans [Sécurité du projet](#)

- Dockeriser le projet

J'ai Dockerisé une ancienne version du projet, voici un exemple du docker-compose

```

version: '3.8'

services:
  web:
    build: .
    container_name: php-apache
    ports:
      - "8080:80"
    volumes:
      - ./src:/var/www/html
    depends_on:
      - db

  db:
    image: mysql:8.0
    container_name: mysql-db
    restart: always
    environment:
      MYSQL_ROOT_PASSWORD: root
      MYSQL_DATABASE: map-la
      MYSQL_USER: user
      MYSQL_PASSWORD: password
    ports:
      - "3306:3306"
    volumes:
      - db_data:/var/lib/mysql
      - ./src/map-la.sql:/docker-entrypoint-initdb.d/map-la.sql:ro

volumes:
  db_data:

```

- Export automatique de la base de données

J'ai créé un script qui extrait toutes les données de la base de données et génère automatiquement un fichier SQL à partir de ces données. Un second script exécute le premier script de manière automatique afin de conserver une copie de la base de données en cas de problème.

- Amen :
- Création de test de stress

J'ai fait un test de stress avec K6 mais qui n'a pas été retenue. Ce test consistait à tester la connexion de 10 utilisateurs simultanés sur le site.

```

PS C:\xampp\htdocs\map-LA-upg> k6 run test.js

  Grafana
  K6

execution: local
script: test.js
output: -

scenarios: (100.00%) 1 scenario, 10 max VUs, 1m0s max duration (incl. graceful stop):
  * default: 10 looping VUs for 30s (gracefulStop: 30s)

TOTAL RESULTS
HTTP
http_req_duration.....: avg=110.41ms min=46.87ms med=771.43ms max=1.46s p(90)=991.64ms p(95)=1.16s
{ expected_response:true }.....: avg=110.41ms min=46.87ms med=771.43ms max=1.46s p(90)=991.64ms p(95)=1.16s
http_req_failed.....: 0.00% 0 out of 215
http_reqs.....: 215 7.054653/s

EXECUTION
iteration_duration.....: avg=1.41s min=1.04s med=1.27s max=2.46s p(90)=1.99s p(95)=2.16s
iterations.....: 215 7.054653/s
vus.....: 10 min=10 max=10
vus_max.....: 10 min=10 max=10

NETWORK
data_received.....: 978 KB 32 MB/s
data_sent.....: 21 KB 691 B/s

running (0m30.5s), 00/10 VUs, 215 complete and 0 interrupted iterations
default [=====] 10 VUs 30s

```

- Création de test Playwrith

J'ai commencé à écrire des tests Playwrith notamment un test de connexion de l'utilisateur. Ces tests ont été repris par Enzo. J'ai donc complété un test de Zoom.

- ~~Création de test Lighthouse~~

J'ai effectué des tests d'avant et après projet avec Lighthouse.

- ~~Rédaction du rapport d'optimisation~~

J'ai rédigé le rapport d'optimisation dans lequel j'ai listé les différentes améliorations que nous avons apportées à notre projet.

Sécurité du projet

Détail des protections

Protection page index.php :

Nom de la protection	Détail
session.cookie_httponly	Empêche l'accès au cookie de session via JavaScript (protection contre les attaques XSS).
session.cookie_secure	Le cookie de session est transmis uniquement en HTTPS (à 0 car on utilise pas HTTPS).
session.use_strict_mode	Refuse les ID de session non valides (renforce la sécurité des sessions).
display_errors = 0	Évite d'afficher les erreurs à l'utilisateur (ne pas exposer d'informations sensibles).
log_errors = 1	Active la journalisation des erreurs pour les administrateurs.
X-Content-Type-Options: nosniff	Empêche le navigateur de deviner le type de contenu (protection contre certains XSS).
X-Frame-Options: SAMEORIGIN	Empêche l'inclusion du site dans une iframe (protection contre les attaques clickjacking).
X-XSS-Protection: 1; mode=block	Active le filtre XSS du navigateur (utile pour certains navigateurs anciens).

Referrer-Policy: no-referrer	Ne transmet pas l'URL référente, protégeant la vie privée de l'utilisateur.
session_start()	Démarre la session utilisateur de façon sécurisée.
csrf_token dans les formulaires	Protège les formulaires contre les attaques CSRF (Cross-Site Request Forgery).
Vérification de connexion isLoggedIn()	Empêche l'accès à certaines fonctionnalités sans authentification.
Fichiers inclus séparés en scripts/	Organise les traitements sensibles et permet de mieux les sécuriser individuellement.
Forçage HTTPS (<i>Prêt mais non utilisé car le site n'est pas en HTTPS</i>)	Redirige les utilisateurs vers la version sécurisée HTTPS (sécurité des échanges réseau).
Content-Security-Policy(<i>Prêt mais non utilisé car la map ne s'affiche plus</i>)	Bloque le chargement de ressources externes non autorisées (protection XSS, injection).
Fonction <code>toggleConsoleLogs</code>	Levier de désactivation des fonctions de consoles

Page Connexion.php :

Nom de la protection	Détail
Démarrage sécurisé de session	session_start() uniquement si aucune session n'est active (session_status() === PHP_SESSION_NONE).
Expiration automatique de session	La session expire après 15 minutes d'inactivité (\$_SESSION['LAST_ACTIVITY'] vérifié et remis à jour).

Jeton CSRF	Un csrf_token est généré avec random_bytes() et vérifié avec hash_equals() lors de l'envoi du formulaire.
Connexion PDO sécurisée	Utilisation de requêtes préparées (\$stmt = \$pdo->prepare(...)) pour éviter les injections SQL.
Validation de l'email	Email validé avec filter_input() et FILTER_VALIDATE_EMAIL.
Validation du mot de passe	Vérification que le mot de passe contient au moins 8 caractères.
Vérification du mot de passe haché	password_verify() utilisé pour comparer le mot de passe avec le hash stocké en base.
Régénération de l'ID de session	session_regenerate_id(true) effectué après une connexion réussie pour éviter les attaques de fixation de session.
Protection contre XSS (pseudo)	Le nom d'utilisateur est échappé avec htmlspecialchars() avant d'être stocké en session.
Limitation des tentatives de connexion (anti-brute force)	Les tentatives sont enregistrées en session et limitées à 5 sur 15 minutes.
Nettoyage des tentatives expirées	Les tentatives de plus de 15 minutes sont supprimées de \$_SESSION['login_attempts'] via array_filter().
Vérification de la méthode HTTP	Le traitement du formulaire ne se fait que si \$_SERVER['REQUEST_METHOD'] === 'POST'.

Page inscription.php :

Nom de la protection	Détail
Démarrage sécurisé de session	session_start() uniquement si aucune session n'est active (session_status() === PHP_SESSION_NONE).

Génération de token CSRF	Un csrf_token est généré avec random_bytes() et stocké en session, puis vérifié avec hash_equals() à la soumission du formulaire.
Limitation des tentatives d'inscription (anti-bot / anti-spam)	Maximum 5 tentatives d'inscription autorisées toutes les 15 minutes par IP (stockées dans \$_SESSION['register_attempts']).
Validation du pseudo (username)	Le pseudo est validé avec une regex : lettres, chiffres, underscore (_), entre 3 et 30 caractères.
Validation du nom complet	Le nom complet est validé avec une regex : lettres, espaces, accents, tirets et apostrophes, entre 3 et 60 caractères.
Validation de l'email	L'email est nettoyé avec trim() et validé avec filter_input(..., FILTER_VALIDATE_EMAIL).
Validation de la robustesse du mot de passe	Mot de passe doit avoir ≥ 8 caractères , 1 majuscule , 1 chiffre , et 1 caractère spécial (fonction isPasswordStrong).
Protection contre les doublons d'email	Vérification que l'email n'existe pas déjà dans la base (SELECT COUNT(*) FROM users WHERE email = ?).
Hachage du mot de passe	Le mot de passe est haché avec password_hash(..., PASSWORD_BCRYPT).
Protection contre XSS (données session)	Le pseudo et le nom complet sont échappés avec htmlspecialchars() avant d'être utilisés.
Insertion sécurisée en base	Requêtes SQL préparées (\$pdo->prepare(...)) pour éviter les injections SQL.
Regénération de l'ID de session	Après inscription réussie, session_regenerate_id(true) est appelé pour éviter les attaques de fixation de session.
Vérification de la méthode HTTP	Le traitement n'est déclenché que si la requête est un POST et contient le champ register.

Page [changepassword.php](#) :

Nom de la protection	Description
session_start()	Démarre une session PHP pour accéder aux variables de session (comme le token CSRF ou l'adresse email de réinitialisation).
Token CSRF (csrf_token)	Empêche les attaques CSRF en vérifiant que le formulaire soumis contient un token unique identique à celui stocké dans la session.
Validation du lien de réinitialisation (token)	Vérifie que le lien de réinitialisation contient un token (\$_GET['token']) qui correspond à celui stocké en session. Cela empêche les usages non autorisés.
Validation de l'email	Vérifie que l'email associé à la session (\$_SESSION['password_reset_email']) est bien présent avant de permettre la modification du mot de passe.
Vérification de la longueur du mot de passe	S'assure que le nouveau mot de passe contient au moins 8 caractères, ce qui renforce la sécurité.
Vérification de confirmation du mot de passe	Vérifie que les deux mots de passe saisis sont identiques pour éviter les erreurs de frappe.
Hachage du mot de passe (password_hash)	Hache le mot de passe avec l'algorithme bcrypt avant de le stocker dans la base de données, rendant sa récupération presque impossible.
Requête préparée PDO	Utilise une requête préparée pour éviter les injections SQL lors de la mise à jour du mot de passe.
Suppression des données sensibles de session	Supprime les variables de session sensibles (email, reset_token, csrf_token) après le changement de mot de passe pour empêcher toute réutilisation.
Redirection après succès	Redirige l'utilisateur vers une URL spécifique après un succès pour éviter une double soumission du formulaire.

Encodage HTML (htmlspecialchars)	Protège contre les injections HTML/JS dans les messages d'erreur ou les valeurs affichées, en encodant les caractères spéciaux.
---	---

Conclusion

État du projet

Le projet est fonctionnel et disponible pour tous via ce lien /.

Toutes les tâches établies ont été réalisées, et nous en sommes plus que satisfaits.

Conclusions personnelles (qu'est-ce que nous avons appris, les choses que le projet a confirmées ou remis en cause)

Enzo : J'avais énormément appris du projet précédent. Malgré cela, j'estime avoir presque autant appris de cette nouvelle version de Zelda: Link's Awakening. Même si les changements ne sont pas "longs comme le bras", ils sont tout aussi importants car ils remplacent d'anciennes fonctionnalités, algorithmes et visuelles plus fragiles. C'est donc très intéressant de s'acharner à imaginer et peaufiner dans les moindres détails les fonctionnalités qui peuvent être améliorées. Par ailleurs, j'ai découvert la mise en place d'un projet dans Docker, et de son potentiel.

John : J'ai beaucoup appris sur les différentes attaques ciblant les sites internet, et surtout sur les méthodes permettant de les contrer, c'était très intéressant. J'ai également acquis des compétences en extraction et en traitement de données grâce à l'export de la base de données, enfin, j'ai appris à virtualiser un projet et est était agréablement surpris de son utilité.

Amen : J'ai beaucoup appris de ce projet, notamment sur les différents types de test et leurs utilités. Les différentes raisons qui servent à choisir un test plutôt qu'un autre, comme les tests unitaires que nous n'avons pas faits, car notre application n'avait de notion métier en particulier.

Prolongements imaginés pour le projet

Il y a plusieurs prolongements possibles.

L'idéal serait d'ajouter d'autres cartes de l'univers Zelda à l'application tel que par exemple Zelda : Echoes Of Wisdom, Zelda : Breath Of The Wild, etc. Elle serait alors toutes concentrées dans une seule et même application, ce qui serait un atout pour attirer de nouveaux utilisateurs, mais aussi de praticité pour ces derniers (tous ceux dont ils ont besoins dans une seule et même application).

Ce qui est important de noter ici, c'est que nous avons réussi à implémenter des prolongements que nous avons imaginés pour une version future de Zelda: Link's Awakening.

Les choix technologiques et architecturaux étaient-ils bons ?

Dans l'ancien projet, nous avons noté que le système de filtres et de modification en BDD était bancal à cause des rafraichissements. Nous avons donc résolu ce gros point noir avec des choix technologiques et architecturaux selon nous plus que correcte.

Nous pensons donc avec humilité que nos choix technologiques et architecturaux sont parfaits ou du moins largement suffisants.

Quels seraient les axes d'amélioration pour vos futurs projets

Les axes d'améliorations pour nos futurs projets pourraient se résumer à cette liste :

- Une meilleure volonté et force de travail pour certains membres du groupe ;
- Un compte admin directement intégré à l'application. Ce compte permettrait de gérer les marqueurs communs (d'en ajouter/supprimer, de modifier leurs données) et de pouvoir avoir une gestion des comptes (ajout/suppression, modification de leurs données et de leurs marqueurs personnelles). En bref la des données de PHPMYAdmin disponible sur un compte admin directement depuis l'application.